

Glossary: Penetration Testing: Planning and Discovery Phases

Welcome! This alphabetized glossary contains many of the terms in this module. This comprehensive glossary also includes additional industry-recognized terms not used in course videos. These terms are important for you to recognize when working in the industry, participating in user groups, and participating in other certificate programs.

Term	Definition
Ambulance telemetry	The remote monitoring and transfer of a patient's clinical health status from an ambulance to a hospital allows real-time decision-making and preparedness for patient arrival.
Application pen test	Penetration tests focus on finding vulnerabilities in applications and related systems, including web applications, websites, mobile apps, IoT apps, cloud apps, and APIs.
Attack phase	The phase in penetration testing where testers execute attacks based on discovered vulnerabilities, using techniques like SQL injections, cross-site scripting, denial-of-service attacks, and more.
Banner grabbing	A technique that sends requests to open ports to gather information about the services and versions running on a host.
Black-box testing	A type of penetration testing where testers have no prior knowledge of the target system and must rely on their research to simulate an attack.
Brute force attack	An attack method that involves systematically trying all possible combinations of passwords or encryption keys until the correct one is found.
Cleanup and reporting phase	The final phase in penetration testing is where testers remove any remnants of their activities and compile a detailed report of identified vulnerabilities, exploitation methods, and recommendations.
Communication plan	A structured plan that ensures transparency and coordination throughout the penetration test via regular updates and defined communication channels.
Containment	Part of the incident response plan involves limiting the impact of an incident during a penetration test.
Cross-Site Scripting (XSS)	An attack technique where attackers inject malicious scripts into web applications to target users.
Cybersecurity	The practice of protecting networks, computers, and data from hacking, unauthorized access, or theft.
Debriefing sessions	Post-testing meetings where findings are discussed and remediation strategies are planned.
Denial-of-Service (DoS) attack	An attack technique that attempts to overwhelm a system, making it unavailable to users.
Discovery phase	The phase in penetration testing is where testers gather data on the target system using reconnaissance methods like source code analysis, packet analyzers, and open-source intelligence (OSINT).
DNS enumeration	The process of gathering information about domain names, IP addresses, and DNS records associated with a target network.
Dumpster diving	The practice of searching through discarded materials, such as trash or electronic devices, to find valuable information like passwords or financial records.
Ethical hacking	A broader field of cybersecurity that uses hacking skills to improve network security, with penetration testing being one of the techniques used by ethical hackers.
Exploitation	A testing method where vulnerabilities are actively exploited to understand their potential impact.
External network pen test	A test that simulates external hackers attempting to breach the network from outside by targeting servers, routers, websites, and employee computers.
False positives	Incorrect results in vulnerability detection, where a security flaw is mistakenly identified, which penetration testing minimizes due to active exploitation of weaknesses.
General Data Protection Regulation (GDPR)	A European Union regulation that mandates strict data protection and privacy controls, which can be confirmed through penetration tests.
Gray-box testing	A type of penetration testing where testers are provided with limited information, such as IP ranges, and must independently identify vulnerabilities within those ranges.
Hardware pen tests	Penetration tests focus on vulnerabilities in devices connected to the network, including laptops, mobile and IoT devices, and operational technology (OT).
Health Insurance Portability and Accountability Act (HIPAA)	A U.S. regulation that requires specific security controls to protect patient information, supported by penetration tests.
Incident response plan	Protocols for managing incidents that may arise during penetration testing, including containment, mitigation, and notification.
Injection points	Locations within a system, such as login functionalities, are vulnerable to attacks like SQL injection.
Internal network pen test	A test that simulates the behavior of malicious insiders or individuals with stolen credentials, seeking to exploit vulnerabilities within the network.

Term	Definition
ISO/IEC 27001	A voluntary information security standard that penetration tests can support by confirming the effectiveness of security controls.
Keylogger	A malicious program is used to capture keystrokes from a user's device, often used in penetration testing to gather sensitive information like passwords.
Lateral movement	The process of penetration testing is where attackers move within a system after gaining initial access to exploit additional vulnerabilities.
Legal and compliance considerations	The process of obtaining necessary permissions and ensuring that the penetration test complies with relevant laws and regulations.
Malware	Malicious software is designed to harm, exploit, or compromise the functionality of a computer system or network.
Malware analysis	A service provided by ethical hackers that involves examining malicious software to understand its behavior, impact, and methods of operation.
Man-in-the-Middle (MitM) attack	An attack technique where the attacker intercepts and possibly alters communication between two parties.
Network mapping	The process of identifying live hosts, open ports, and services on a network using tools like Nmap.
Network pen tests	Penetration tests target a company's entire network, including both external and internal tests, to find vulnerabilities in internet-facing assets and within the network itself.
Nmap	A network mapping tool that lists active devices, services, and open ports on a network.
Open-Source Intelligence (OSINT)	Information gathered from public sources is used in penetration testing to gain insights into the target system.
Operational Technology (OT)	Hardware and software that detects or causes changes through direct monitoring or control of physical devices, processes, and events.
OWASP Top 10	A periodically updated list of the most critical web application vulnerabilities, often used as a starting point in application pen tests.
Passive reconnaissance	A method of gathering information about a target system without directly interacting with it, minimizing the risk of detection.
Payment Card Industry Data Security Standard (PCI-DSS)	A regulation that requires organizations processing credit card transactions to conduct regular "external and internal penetration testing" to ensure security compliance.
Pen test scope	A detailed outline that specifies the areas and systems to be tested during penetration testing.
Penetration test (Pen test)	A simulated cyberattack is conducted by cybersecurity experts to identify and exploit vulnerabilities in a computer system's security.
Personnel pen test	Penetration tests that evaluate employees' cybersecurity practices and the organization's vulnerability to social engineering attacks.
Phishing	A social engineering attack where attackers send fraudulent emails to trick recipients into revealing sensitive information.
Ping sweeps	A technique that scans IP addresses to identify which are in use, helping pen testers locate live hosts on a network.
Planning phase	The initial phase of penetration testing is where the testing team collaborates with clients to define the test's scope, systems to be examined, and testing methodologies.
Port scanners	Tools used to detect open ports on a network can indicate potential vulnerabilities.
Post-testing procedures	Steps taken after completing the pen test, such as debriefing sessions, data analysis, and implementing remediation measures.
Privilege escalation	A technique where attackers gain higher-level permissions within a system, allowing them to access more sensitive data.
Reconnaissance	The process of gathering information about a target system during the discovery phase of penetration testing.
Regulatory compliance	Adherence to data security regulations like HIPAA and GDPR, which require specific security controls and can be supported by penetration tests.
Remediation measures	Actions taken to fix identified vulnerabilities after a penetration test.
Remnants	Traces left behind by pen testers during the verification phase must be removed during the cleanup phase.
Resource allocation	The process of assigning personnel, tools, and budget to ensure the penetration test's success.
Risk assessment	Identifying and evaluating potential risks associated with the penetration test to minimize disruptions and address vulnerabilities.
Scope specification	Part of the pen test scope includes identifying the systems to be tested, the schedule, and the testing methodologies.
Security controls	Measures designed by security teams to protect networks from cyber threats are often informed by the findings of penetration tests.

Term	Definition
Smishing (SMS Phishing)	A social engineering attack where attackers send deceptive text messages to gain sensitive information.
Social engineering	An attack technique where testers trick individuals into divulging sensitive information through methods like phishing.
Social engineering attacks	Manipulative techniques used by attackers to trick individuals into divulging sensitive information are often assessed through personnel pen testing.
SQL injection	An attack technique used in the attack phase to exploit vulnerabilities in a system's database by injecting malicious SQL queries.
Tailgating	A physical security breach tactic where an unauthorized individual gains access to a secure area by following an authorized person.
Testing methods	The specific methodologies and tools used during penetration testing, such as vulnerability scanning and social engineering.
Third-party security experts	External cybersecurity professionals who conduct penetration tests from an outsider's perspective, often uncover flaws that in-house teams might miss.
Traceroutes	A method that traces the path data takes across a network, revealing its structure and potential bottlenecks.
Verification phase	The phase in penetration testing where testers verify the efficiency and impact of exploited vulnerabilities and refine their techniques to bypass defenses.
Vishing (Voice phishing)	A social engineering attack where attackers use phone calls to trick individuals into divulging confidential information.
Vulnerability	A weakness in a computer system that can be exploited by attackers during penetration testing.
Vulnerability assessment	Automated and recurring scans designed to detect known vulnerabilities within a system, flagging them for review by security teams.
Vulnerability chaining	A process in penetration testing where testers exploit an initial vulnerability and then move deeper into the system, chaining attacks to cause more significant damage.
White-box testing	A type of penetration testing where testers are provided with full access and knowledge of the system, enabling them to find vulnerabilities that could go undetected with less information.
Zero-day vulnerability	A previously unknown security flaw that hackers can exploit before the vendor has issued a patch.



Skills Network